

Governance Root Cause Analysis: Equifax 2017 Data Breach

Prepared for the Board Risk Committee and Executive Leadership
External Governance & Cybersecurity Consultant

Executive Summary

In 2017, Equifax one of the largest consumer reporting services (CRA) was breached leading to exposure of Personally Identifiable Information (PII) of 145.5 million American citizen. The threat actors were able to exploit the well-known Apache Struts vulnerability which was publicly known and patchable for months before intrusion.

The central finding was that the breach itself was preventable as patch existed and internally the scanner flagged the vulnerability. What failed was governance architecture at all the three lines where policies were not verified, no evidence of task existed and failed oversight function. If these would have been working as they were meant to be, the vulnerability would have surfaced much earlier before hackers exploited it.

The three lines in case of Equifax failed simultaneously and in mutually reinforcing ways, which led to loss of early warning signs and converted the small risk into a crisis. The first line failed to identify and verify the security work. The second line failed to monitor, challenge and escalate effectively. The third line did not validate if controls were operating in practice.

This report identifies the root cause which caused the breach and connects them to the observed impacts on Equifax. Further the report also presents prioritized recommendations for Board Risk Committee and Executive leadership. The recommended actions are divided into quick wins which can be implemented within a span of 30-45 days. And structural reforms require 60-90 days. Collectively the report can help Equifax to transform document-oriented structure into operational evidence based model.

Incident Overview

In 2017, Equifax, one of the three largest consumer reporting agencies in the United States, suffered a data breach exposing the personally identifiable information of approximately 145.5 million Americans. The breach was traced to the exploitation of CVE-2017-5638, a critical vulnerability in Apache Struts, a widely deployed web application framework. A patch had been publicly available since March 7, 2017. Equifax issued an internal directive to apply for it within

48 hours. The vulnerable system remained unpatched when attackers gained access on May 13, 2017. The intrusion went undetected for 78 days. The technical facts for this breach are well documented.

This report examines the deeper aspects of breach helping the reader to understand why a well-known, fixable vulnerability persisted long enough to make it one of the most sensational data breaches in the world. The answer lies in the failure of implemented governance structure.

Three Lines Analysis

First line: operational management

The first line at Equifax encompassed the engineering, IT operations, and application teams responsible for day-to-day security execution, including the identification, prioritization, and remediation of known vulnerabilities. Their core accountability was to own the risks created by their systems and translate policy directives into verified operational outcomes.

When the Apache Struts vulnerability was disclosed in March 2017, an internal directive to patch within 48 hours was circulated to over 400 employees with no named owner, no confirmation mechanism, and no escalation deadline. The developer with the technical knowledge to act was not even on the distribution list, and his manager received the alert but did not forward it. This was not individual oversight. It was a consequence of a governance structure which had no clear accountability.

The operational failure was compounded by three structural weaknesses that made execution nearly impossible even where intent existed. First, Equifax had no comprehensive IT asset inventory. Hence, teams could not reliably identify where the vulnerable Apache Struts library was deployed across the technology stack, rendering targeted remediation and verification structurally impossible. Second, patch completion was validated through what the Senate Subcommittee called an "honor system". Honor System allowed teams to self-reported completion, and security team assumed success if a subsequent scan showed nothing. No evidence, no confirmation nor closure from teams was needed. Third, operational controls were treated as one-time deployments rather than ongoing responsibilities. An SSL certificate on the dispute portal, the very system through which attackers entered, had expired eight months before the breach was detected. This left network monitoring blind for the entire duration of the intrusion. These were not isolated failures. They reflect a first line operating without the governance infrastructure needed to execute, verify, and maintain security controls reliably.

First line root causes:

Root Cause	Evidence	Risk Impact
No clear ownership for patch remediation	Alert sent to 400 people; patch policy roles never filled; key developer excluded from distribution list	No single accountable owner drove execution or verification
No IT asset inventory	Could not locate Apache Struts deployments; scan missed ACIS system entirely	Targeted remediation was structurally impossible.

Root Cause	Evidence	Risk Impact
Honor system instead of evidence-based verification	Self-reporting accepted as proof; security assumed success if scan showed nothing	False assurance replaced actual security
No lifecycle management for controls	300 expired SSL certificates; monitoring device inactive for 8 months prior to breach	Attackers operated undetected for 78 days because a basic maintenance task had no owner
Leadership tone deprioritized security	CIO: patching was 'six levels down'; director confirmed 'security wasn't first'	Organizational signal made security compliance optional in practice regardless of written policy
Known weaknesses unaddressed for two years	2015 audit found 8,500 unpatched vulnerabilities including 1,000 on external-facing systems	Documented critical risks persisted without correction or escalation for two years before the breach

Second line: risk, compliance, and security

The second line at Equifax comprised the security GRC teams/employees including the Global Threat and Vulnerability Management team, the Chief Security Officer, and senior IT leadership. Their mandate was to set standards, monitor first-line adherence, and challenge operational decisions when risks exceeded tolerance. The second line's effectiveness depends critically on its independence from day-to-day operations. It must observe, challenge, and escalate without owning the work itself.

The second line's effectiveness was undermined by following failures: First, Equifax had no effective oversight mechanism to track and validate the actions taken. The GTVM meetings were primary source through which Equifax shared critical information to people of authority. However, these meetings were considered more information sharing sessions rather than governance controls. The GTVM meetings failed to carry forward vulnerabilities from March to July assuming they were fixed. There was no tracking for vulnerabilities closure nor were there any established escalation paths. The governance at second line failed mainly because the oversight forum lacked action tracking and escalation paths which should have provided deeper insight into patch management.

The second line at Equifax had gotten converted to passive observers as the risk intelligence and threats never reached the people of authority. The monthly GTVM meetings were not attended by CSO, the SVP of Product Security, and the CIO nor the senior management requested summaries or dashboards to receive output. Second line also failed at challenging and verify the operational line because of the "Honor system", hence no evidence was ever gathered or requested to verify the compliance process outcomes.

Finally, the second line also failed to follow through 2015 audit findings. The second line neither tracked or remediated nor it escalated if they were not patched for certain amount of time the 8500 unpatched vulnerabilities, including 1000 on externally facing systems.

Second line root causes:

Root Cause	Evidence	Risk Impact
Risk oversight forum lacked action-tracking	Vulnerabilities dropped off the GTVM agenda; no carry-forward, no owner assignment per risk	Risk identification produced no accountable action
Risk intelligence never reached decision-makers	CSO, SVP, CIO absent from meetings; no summary mechanism established	Leadership could not exercise oversight of risks it was never informed about
Second line abandoned its challenge function	Countermeasures head treated GTVM meetings as informational; passive posture normalized	The function mandated to challenge the first line had stopped challenging
Designed and accepted inadequate verification	Security function built and operated the honor system	The compliance process measured intent not outcomes
No follow-through on 2015 audit findings	2015 findings unaddressed for two years; SVP confirmed no formal follow-up	Known critical risks persisted without second-line challenge or escalation

Third line: internal audit

The third line or internal audit serves as the organization's independent assurance function. Its role is not to set policy or execute controls, but to verify objectively that the first and second lines are operating as intended. The internal audit's defining must be able to report findings without being responsible for the work it reviews, and it must report directly to the board so that findings cannot be suppressed or minimized by the other levels.

The audit committee identified over 8,500 unpatched vulnerabilities including 1,000 on externally-style systems which were serious enough for urgent board attention. However, no single patch was verified for completion. No one challenged the honor system whether it was producing accurate results. Internal audit also failed to challenge the asset inventory before rescanning took place.

The internal audit committee just like second line failed to follow through the found vulnerabilities. There was no formal follow-up audit to verify if the found vulnerabilities were remediated. The SVP of Internal Audit confirmed to the CSO in August 2017, after the breach had already occurred, that there had been "no formal follow-up."

Third line root causes:

Root Cause	Evidence	Risk Impact
Audit tested documentation not operational reality	No patch tracing, no honor system validation, no asset inventory testing in 2015 audit	Paper-based assurance created false confidence
No follow-up after critical findings	SVP confirmed 'no formal follow-up' to 2015 audit; no remediation tracking established	Known critical risks persisted for two years with no organizational response

Organizational and Cultural Factors

Governance failures like Equifax arise from structural defects. In case of Equifax four such conditions occurred, which created an environment which deprioritizes the security compliance at three lines simultaneously.

The most important condition was leadership tone. At Equifax the leadership posture itself was deprioritizing the security infrastructure. This was confirmed when CIO characterized patch management as “lower-level responsibility six levels down” and A director within Equifax's security function confirmed this explicitly, stating that before the breach, "security wasn't first.". This signals that Equifax's leadership was not incentivizing security nor their security functions valued or visible. Naturally this is percolated into the organization prioritizing time and resources for what leadership rewards rather than security functions.

Misaligned incentives lead to business units and operational teams focus more on throughput, prioritizing time, and product availability/delivery. This may have led to teams deprioritizing security functions considering them as downtime or delays. The honor systems were accepted and not challenged as it was easier to verify using honor system as there was a lack of incentive for reverification.

The second line's challenge function was also failed and highly constrained because of under resourcing. This happened because of Equifax's rapid growth, expansion and acquisition producing complex and heterogeneous technology stack. Decline in challenge function led to limited follow ups and selective monitoring limiting the exposure of security functions inside the company. A clear example of this is when 2015 findings went unaddressed for two years confirming that second line was functioning out of mandates.

Finally, at Equifax the cross functional coordination was lacking. There was no chain established through which high risk can be communicated from operational team through executive leadership to boards. A successful patch management requires IT operations, security governance, application owners and compliance to work together with documented decision rights.

Benchmarking: TransUnion and Experian

The most important evidence that Equifax's failures were governance choices rather than technological inevitability comes from its two largest competitors. TransUnion and Experian received the identical CVE-2017-5638 alert on the same day, faced the same technical challenge, and operated in the same regulatory environment. Both avoided a breach.

Area	Equifax	TransUnion	Experian
Asset Inventory	None. Could not locate Apache Struts deployments. Scan missed the breached system entirely.	Full inventory maintained for 3 years. Asset owners defined and accountable per system.	Policy-mandated inventory covering hardware, software, and applications. Designated

Area	Equifax	TransUnion	Experian
			information steward per asset.
Verification	Honor system. Self-reporting accepted as proof. One scan, no recheck.	Weekly full environment rescans. Multiple tools. Issues tracked to closure with dashboards.	Post-patch rescans mandatory. External firm contracted for targeted scan. Vulnerable server found and taken offline.
Response Speed	Never patched ACIS. Patch applied August 2017, five months after disclosure.	Action taken same week as disclosure. Asset owners contacted immediately.	Firewall updated within 2 days. Vulnerable server patched within weeks.

Both competitors maintained the foundational governance infrastructure of asset inventory, evidence-based verification, and rapid escalation that Equifax could not maintain. The 48-hour patch SLA was achievable: TransUnion essentially met it. Equifax's failure was not about the difficulty of the task but was about the weak governance structure.

Prioritized Recommendations

The following five recommendations are sequenced by urgency and impact. Each address one or more root causes identified across the three lines and specified an owner, implementation timeline, and measurable success criteria. Quick wins (P1, P2, P5) can be implemented within 30 to 45 days. Structural reforms (P3, P4) require 60 to 90 days.

P	Recommendation	Owner	Timeline	Success Measure
P1	Board Risk Committee mandates quarterly cybersecurity briefings. CEO makes cybersecurity a named executive accountability appearing in performance reviews. Senior security leaders must attend GTVM meetings or receive mandatory written summaries within 24 hours.	Board Risk Committee / CEO	30 days	Board meeting cadence maintained; dashboard reviewed monthly; GTVM attendance rate tracked; zero missed escalations to board
P2	Replace the honor system entirely. Every critical patch closure requires hard evidence: scanner confirmation,	CISO	45 days	100% of critical patch closures supported by evidence; zero self-reported closures accepted; audit sampling rate quarterly

P	Recommendation	Owner	Timeline	Success Measure
	management ticket, and a named approving authority. Self-reporting is not accepted as proof of completion under any circumstances.			
P3	Build and maintain a comprehensive IT asset inventory covering all hardware, software, and applications across the org, with a named asset owner per system domain. Integrate directly with vulnerability scanning tools. As TransUnion demonstrated, this enables same-week identification of vulnerable systems when a CVE is disclosed.	CIO / IT Operations	60 days	Asset inventory coverage above 95%; scanner-to-inventory reconciliation rate monthly; zero unlocatable assets on internet-facing systems
P4	Restructure internal audit engagements to include patch tracing, scanner output sampling, tabletop exercises. No documentation review alone. Mandatory follow-up audit within 90 days of any critical finding. Chief Audit Executive reports directly to Board Risk Committee quarterly.	Chief Audit Executive	90 days	Percentage of audits with operational testing above 80%; zero repeated critical findings; remediation tracking rate 100%
P5	Establish a tiered escalation protocol with automatic triggers: critical CVE if unpatched beyond 72 hours triggers automatic CISO alert with named owner assignment; beyond 7 days triggers Board Risk Committee notification.	CISO	45 days	Escalation SLA adherence 100%; time-to-executive-notification tracked; zero vulnerabilities aging silently beyond 7-day threshold

Conclusion

The breach at Equifax was preventable as the patch existed, the scanners flagged the vulnerability and internal directive existed. However, due to lack of efficient functioning of governance architecture which could not translate policies into evidence-based operations with efficient oversight functions failed to prevent the breach.

As the report helps discover root causes of this incident which included attestation-based verifications rather than evidence based, risk information never reached people with authority, organizational structure deprioritizing security indicates a failed governance failure rather than technical.

The five recommendations presented here are designed to close each gap systematically. Implementing them will not merely reduce the probability of a recurrence but also it will help transform the Board Risk Committee's visibility into cybersecurity risk and give executive leadership the governance infrastructure needed to exercise meaningful oversight.

This report was prepared based on publicly available information including the U.S. Senate Permanent Subcommittee on Investigations report on the Equifax Data Breach (2019) [[FINAL Equifax Report.pdf](#)] and the U.S. House Committee on Oversight and Government Reform report (2018). [[Equifax-Report.pdf](#)]